〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.22(목)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-22(목), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· 포털 방어 기능 실전 테스트 및 pfSense 네트워크 경계 노출 여부 확인

· R3·R11·R12(AI 보안 탐지) Graylog 연동과 Wazuh FIM·웹 스캔 탐지 점검

· 전자결재·보안 대시보드 UI 고도화, 프로덕션 WSGI 서버 전환

■ 조원별 활동 내역

▶ 진혜정 (자동화·n8n·상황판)

· 로그인 폼에 연속 실패 요청을 보내 홍주형이 만든 실시간 IP 자동 차단이 실제로 작동하는지 확인(403 발동 확인), 오픈 리다이렉트(next=)·HTTP 요청 스머글링 시도는 모두 방어됨을 확인

· nmap -p- 로 pfSense(192.168.3.10) 전체 포트를 스캔해 5070 외에도 n8n 콘솔(5678)·Graylog 콘솔(9000)·DB(3306)·Ollama API(11434)·nginx(8080)가 외부로 그대로 포워딩되고 있는 것을 발견 — 포털에서 차단된 공격 IP로도 이 서비스들에 직접 접근 가능했음(오늘 가장 중요한 발견)

· 이시헌에게 pfSense NAT/방화벽 규칙 정리를, 김태빈에게는 같은 대역 내부는 pfSense를 거치지 않는 점을 고려해 호스트 방화벽으로 접근 IP 제한을 요청 — 두 사람 조치 진행 중으로 확인

▶ 홍주형 (웹·DB 하드닝)

· 전자결재 결재선에 도장(직인) 컴포넌트(〔상신〕/〔승인〕/〔전결〕/〔반려〕)와 간접비 지출결의서 표준 그리드 서식 적용

· 보안 대시보드 감사로그를 Master-Detail 구조로 전면 개편 — 상단 목록은 폰트·패딩 축소로 가로 스크롤 제거, 하단에 판정 사유·상세 파라미터·SIEM JSON 원문(복사 버튼 포함) 패널 신설, 팝업 모달 방식 폐지

· 개발용 Werkzeug 서버를 프로덕션 WSGI 서버 Waitress(멀티스레드 8개)로 전환, WebSocket 연결 시도 시 500 대신 400으로 안전하게 처리하는 미들웨어 추가

· Waitress 전환 후 pfSense 경유 요청의 실제 클라이언트 IP(192.168.7.77)가 pfSense IP(192.168.3.10)로 잘못 찍히는 문제 발견 — 원인은 Waitress의 clear_untrusted_proxy_headers 기본값(True)이 X-Forwarded-For를 제거하는 것이었고, 옵션을 False로 바꾸고 신뢰 프록시 검증을 Flask 쪽에서 유지하는 방식으로 해결(src_ip/srcip/client_ip 전부 정상 기록 확인)

· DB 포트를 3307:3307로 완전히 일치시키고 바인딩을 127.0.0.1 로 변경 — 외부 LAN(192.168.3.14:3307) 접속 시도는 타임아웃으로 차단, 로컬(127.0.0.1:3307) 접속만 정상 동작하는 것을 확인

▶ 이시헌 (네트워크)

· pfBlockerNG 도입 — Spamhaus·ISC 등 4개 소스에서 받은 악성 IP·광고 도메인 17,100개를 매시간 자동 갱신하며 차단, 사설 테스트 IP(192.168.x, 172.16.x)는 보호 대상에서 제외해 포털 테스트에는 영향 없음

· HAProxy 과속 요청 차단(10초 100건 초과 시 즉시 429) 적용 — 150회 연속 요청으로 직접 검증(1~100번째 200, 101~150번째 429, 12초 후 재시도 200으로 복귀) — 포털 서버 앞단에서 걸러지는 1차 방어선으로 구성

· Suricata IDS 설치(WAN 구간, 포트스캔·SQL인젝션·웹공격 카테고리만 활성화, 리소스 제약으로 차단은 하지 않고 탐지만) — 설치 직후 실제 공격 시도(ET SCAN Sqlmap SQL Injection Scan 등) 탐지 확인

· 세 기능 모두 pfSense 단에서만 추가돼 포털 서버 코드나 기존 기능에는 영향 없음, Graylog 연동은 담당자 영역이라 이번 범위에서 진행하지 않음

▶ 김태빈 (탐지)

· Graylog에 R3·R11·R12(AI 보안 탐지) Event Definition을 구성하고 NEXUS_AI_SECURITY Stream·n8n Notification 연결을 확인

· R3·R11·R12 synthetic 이벤트로 Graylog→n8n→Incident Ticket→Discord 흐름을 전부 검증(n8n은 dry-run 상태 유지, live 대응·자동 차단은 실행하지 않음)

· .14 Wazuh Agent와 .15 Manager 연결, security.jsonl 수집, 404·반복 웹 스캔 탐지를 확인 — Agent 004/nexus-board-14가 Active이고 .15 Threat Hunting에 이벤트가 표시되는 것, 기존 Windows/FIM 이벤트 수신이 유지되는 것까지 확인

· .10:5070 대상 Nikto 테스트로 Graylog R8 웹 스캔 탐지를 확인(이벤트 src_ip는 192.168.3.10으로 표시)

· 같은 상황에서 R3와 R12가 함께 매칭될 수 있는 분류 중복을 발견했으나 탐지 흐름을 막는 오류는 아니라 TODO로만 남김, Nikto 테스트 중 일시적 HTTP 429 발생(원인·위치 미확인, n8n 자동 차단에 의한 것은 아님)

· .14 직접 5070 연결 시간 초과, .10:5070의 /login·/healthz가 HTTP 503을 반환하는 현상을 확인했으나 원인은 특정하지 못함 — .14 방화벽 규칙·Flask listener는 원격 조회 권한이 없어 확인하지 못했고 설정은 변경하지 않음

■ 조원별 의견 및 제안 사항

· 진혜정: 포털 자체 방어는 양호했지만 네트워크 경계(pfSense)의 포트 노출이 더 큰 구멍이었다는 점에서, 앱 레벨 점검과 네트워크 레벨 점검을 항상 같이 해야 한다는 교훈

· 이시헌: 리소스가 제한된 환경에서는 "차단"보다 "탐지만"으로 범위를 좁히는 것도 유효한 선택이라는 걸 Suricata 적용에서 재확인

· 김태빈: R3/R12처럼 서로 다른 규칙이 같은 이벤트에 동시에 매칭될 수 있다는 걸 미리 알아두면, 추후 상황판에서 중복 알림을 사람이 헷갈리지 않게 설계할 수 있음

■ 회의 결과 및 결정 사항

1. pfSense의 불필요한 포트 포워딩(n8n·Graylog·DB·Ollama·nginx)은 이시헌·김태빈이 각자 방화벽 레벨에서 정리하기로 함

2. R3·R11·R12 AI 보안 탐지는 synthetic 검증까지 완료, 실사용자 트래픽 기준 검증은 AI 에이전트 연동 이후 진행

3. 프로덕션 WSGI 전환(Waitress) 및 DB 포트 격리(3307 루프백)를 표준 운영 상태로 확정

4. Suricata는 당분간 탐지 전용으로 유지, 자동 차단(IPS) 전환은 보류

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- R3·R11·R12 AI 탐지가 synthetic E2E 기준으로 Graylog→n8n→Ticket→Discord까지 전부 확인됨
- 포털은 WSGI 엔진 전환과 실제 IP 복원까지 마쳐 로그 신뢰도가 올라감
- pfSense에 pfBlockerNG·속도 제한·Suricata 3종 방어선이 새로 추가됨

· 어려운 점

1. pfSense가 포털 외 다수 관리 포트를 외부로 그대로 열어두고 있던 것이 뒤늦게 발견됨(포털 레벨 방어만으로는 알 수 없던 구멍)
2. .14 직접 접속 503, .10 포트 노출 등 원인 미특정 이슈가 여러 건 남음
3. R3·R12 분류 중복처럼 탐지 규칙 간 경계가 아직 완전히 정리되지 않은 부분이 있음

■ 향후 활동 계획 및 역할 분담

· pfSense·호스트 방화벽 조치 완료 후 포트 노출 재검증(이시헌·김태빈)

· 10/21 채팅에 노출됐던 MYSQL_ROOT_PASSWORD 등 비밀값 로테이션 여부 재확인(진혜정)

· 재검증 후 포털(5070) SQL 인젝션·디렉터리 탐색 등 남은 공격 테스트 이어서 진행(진혜정)

· .15 Windows Firewall에서 관리 UI 포트만 허용 IP 기준으로 제한, .14 5070 listener·방화벽 규칙 서버에서 직접 확인(김태빈)

· R3/R12 분류 중복 여부 정리(김태빈)

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/22) 페이지

- 진혜정 - 10/22 작업 / 2026-10-22 NEXUS WORK 전체 작업 회고록(홍주형) / 10/22일 작업 현황 보고서(이시헌) / 2026-10-22 작업 기록(김태빈, 개인 워크스페이스)